Navigating AiTM and
Device Code Phishing
Attacks in Entra ID

HOOK, LINE, & SESSION

JOHN LAFFERTY
Systems Engineer – Vandalia Health

NATHAN HESS
Information Security Specialist – Vandalia Health



Introductions

ENGINEER

JOHN LAFFERTY

Builds and manages the identity stack.

20+

YEARS

- B.S. Computer Science
- Azure Administrator
- AWS Cloud Admin
- Active Directory
- Automation Scripting

SECURITY

NATHAN HESS

Secures and monitors the same stack.

12

YEARS

- M.S. Cybersecurity
- ISC2 SSCP
- CySA+ · ISC-360
- AZ-900
- SC-300

Top Brand Impersonations in Phishing Attacks



Source: Check Point Research

IDENTITY-DRIVEN INITIAL ACCESS

65%

Identity policy & insider risk – 11%

Credential misuse & brute force – 21%

Identity based Phishing and SE – 33%

Source: Palo Alto Unit42

Trends in AiTM Attacks.

APRIL 2026

35,000

users targeted in 3 days

13,000 organizations · 26 countries
Healthcare the largest vertical at 19%

Code-of-conduct lures. Real Microsoft sign-in proxied. Session cookie stolen. MFA completed and still lost.

2021 – 2022

10,000+

orgs targeted

First large Microsoft AiTM campaign disclosed

2024

10,000+

attacks / month

Reported run-rate against Microsoft users

Jul 23 – Jun 24

+146%

year over year

Microsoft Digital Defense Report 2024

H2 25 – Q1 26

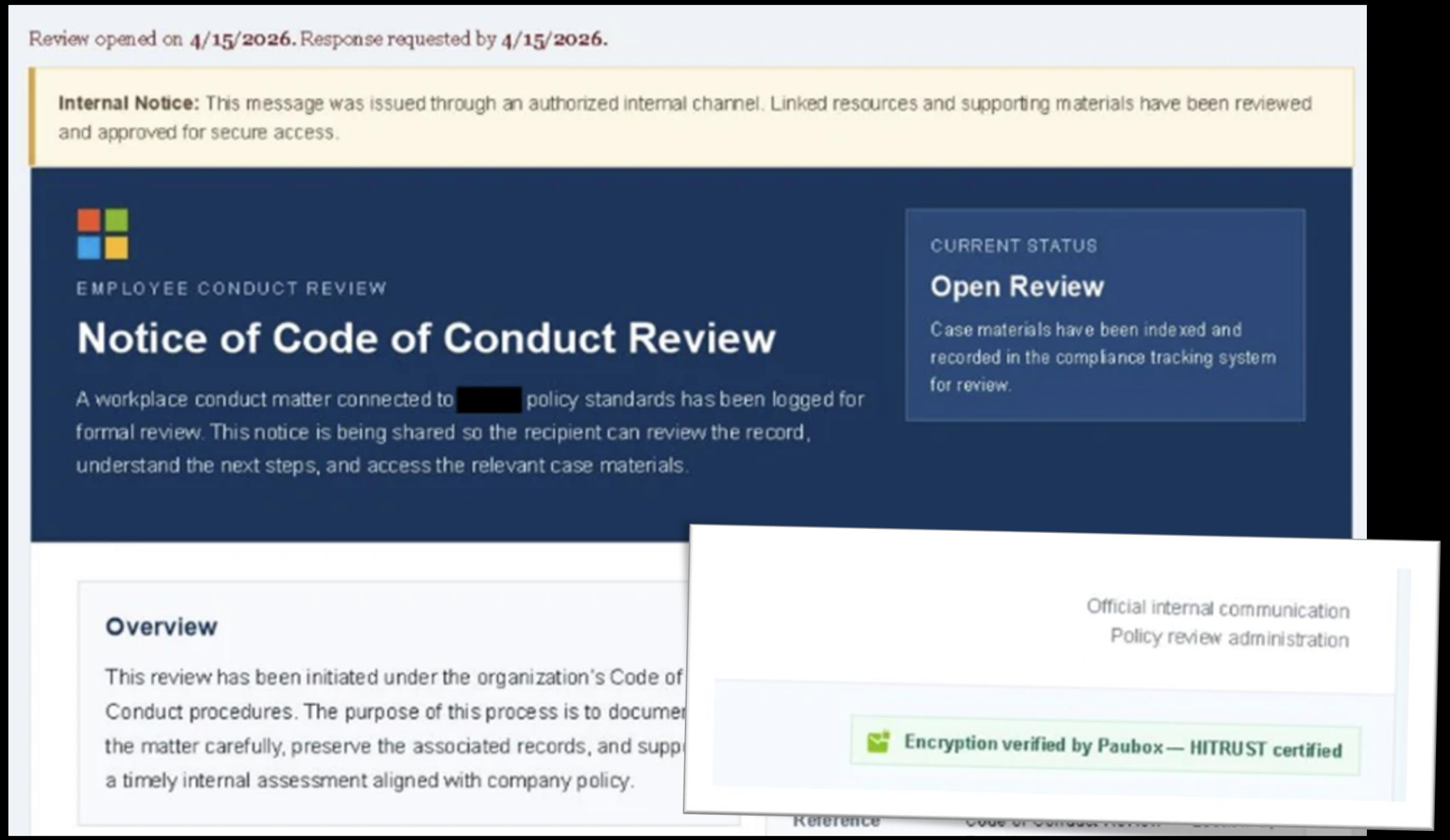
+139%

in six months

KnowBe4: reverse-proxy / AiTM kits

Sources: Microsoft 2022 AiTM disclosure; Digital Defense Report 2024; Apr 2026 campaign (14–16 Apr); KnowBe4 Phishing Threat Trends Vol. 7 via PhishEye 2026.

2026 Code of Conduct Campaign



Source: Microsoft



Adversary-in-the-Middle

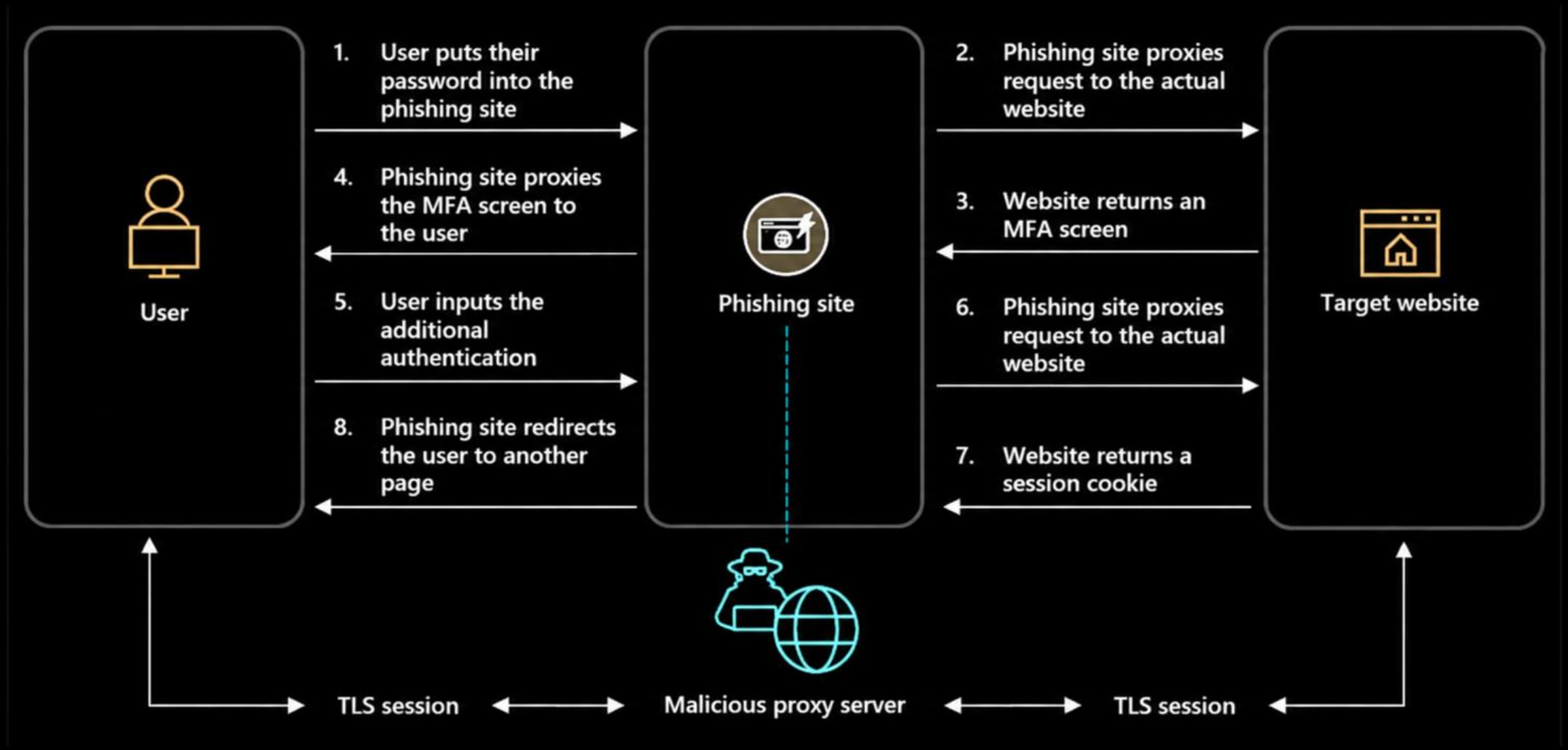
A phishing proxy relays the real sign-in and steals the password plus the session cookie. Defaults have no token protection.



Device Code Phishing

The user types an attacker-generated code on a real Microsoft page. The token is issued to the attacker’s device. Defaults are not a CA policy you can tune.

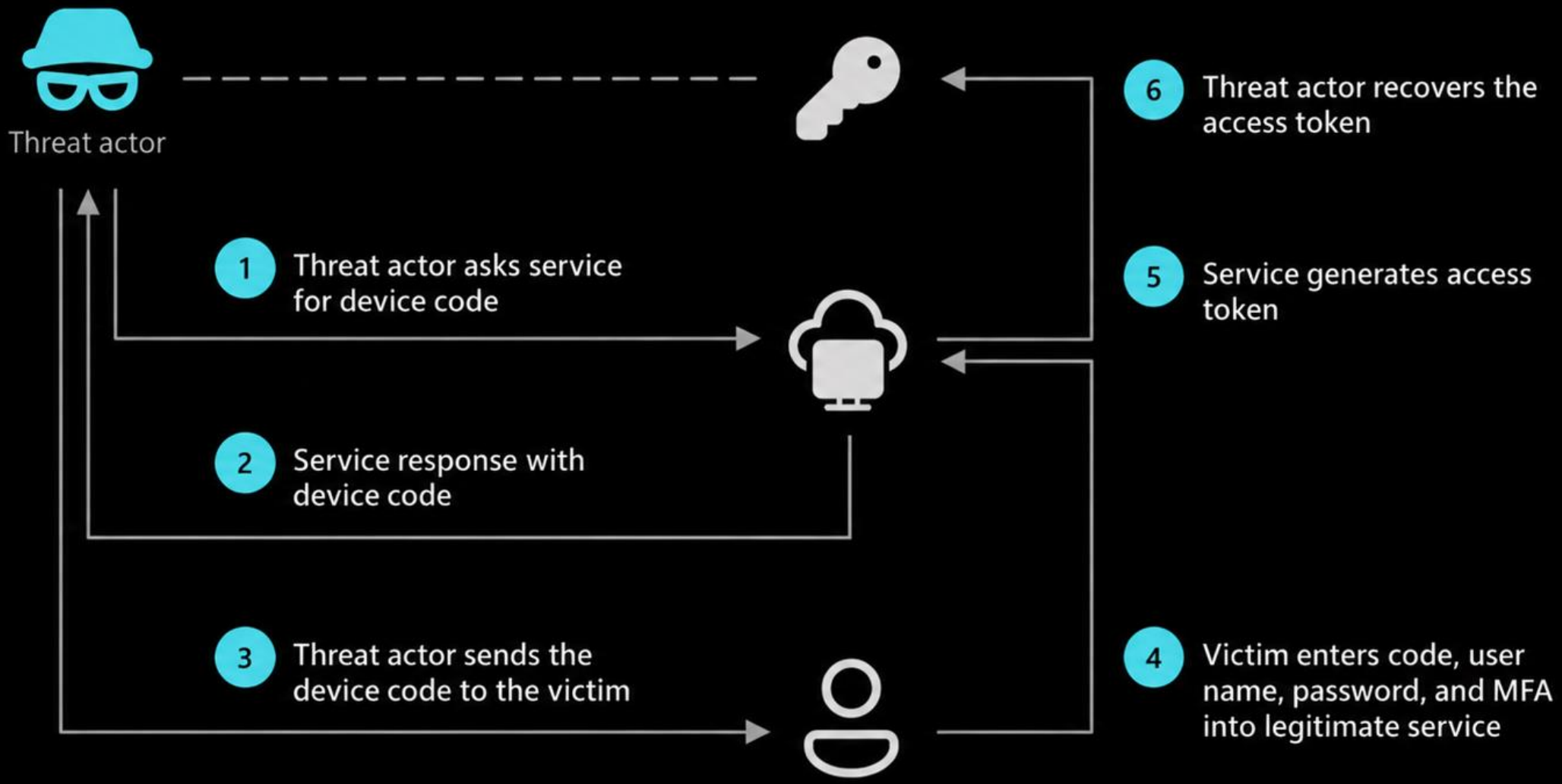
Adversary-in-the-Middle

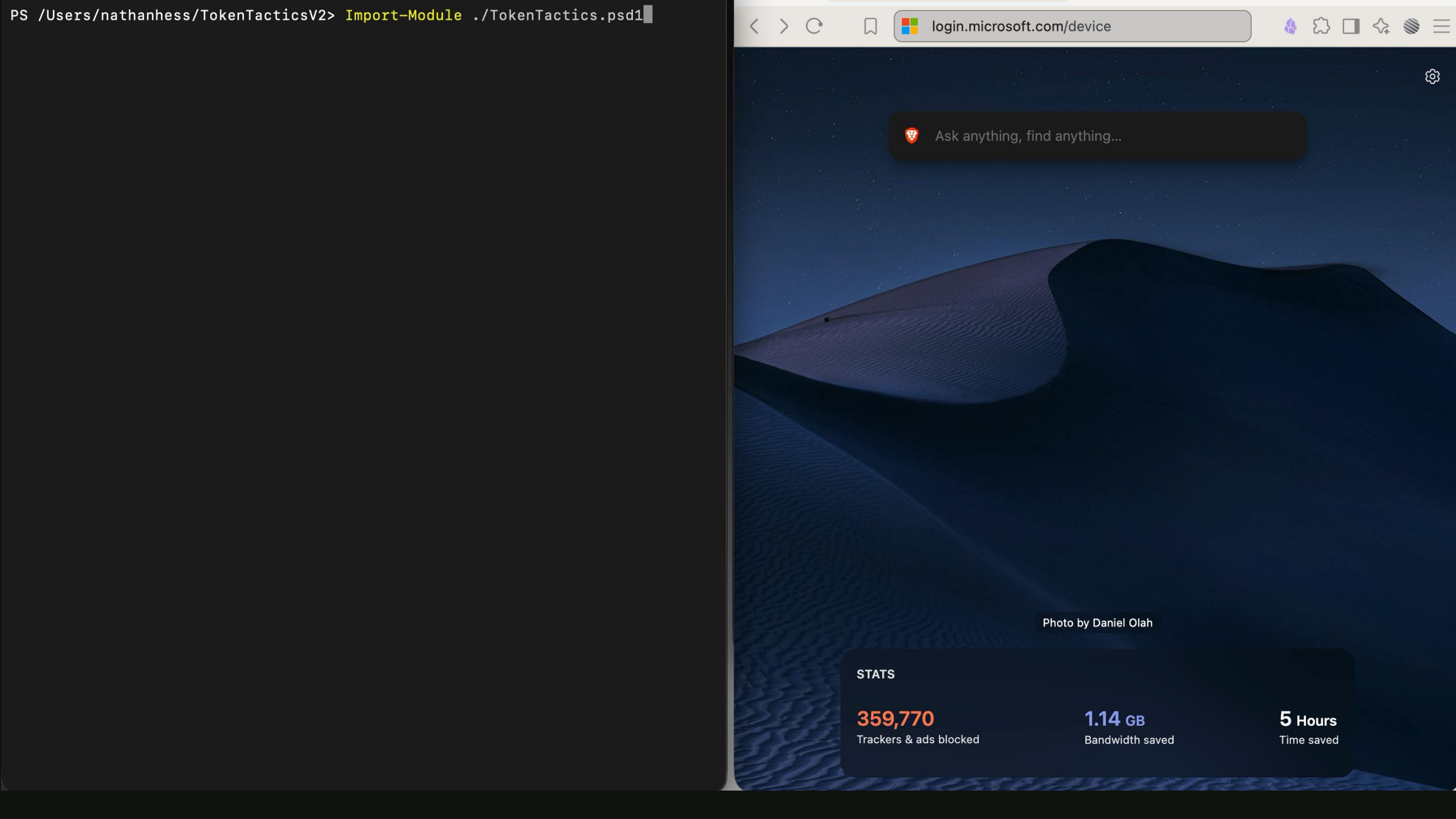


Source: Microsoft

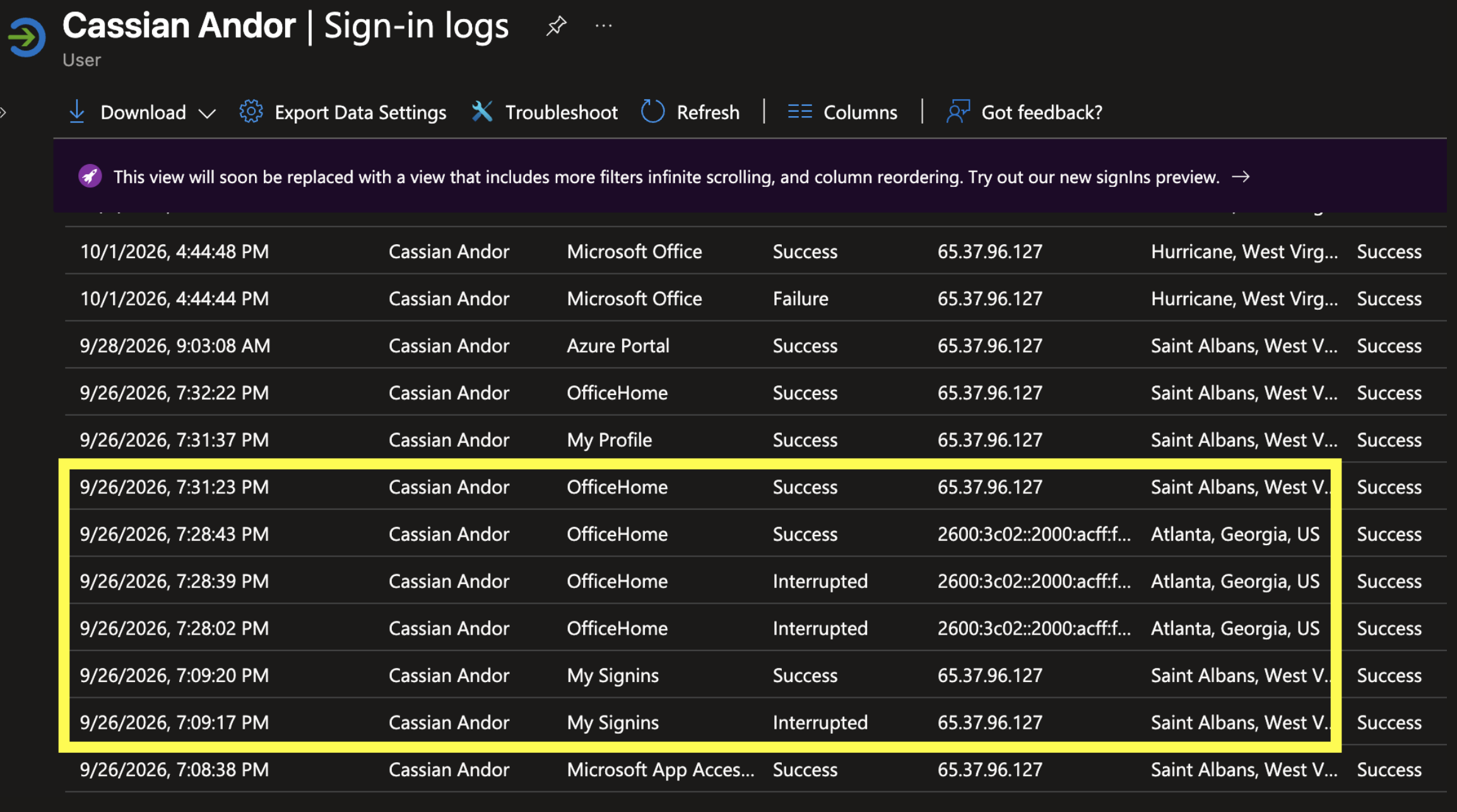
```
root@localhost:~/evilginx2# ./evilginx2
```

Device Code Flow Phishing




PS /Users/nathanhess/TokenTacticsV2> Import-Module ./TokenTactics.psd1
login.microsoft.com/device
Ask anything, find anything...
Photo by Daniel Olah
STATS
359,770
Trackers & ads blocked
1.14 GB
Bandwidth saved
5 Hours
Time saved

Hunting for AiTM Activity



Hunting for AiTM Activity

9/26/2026, 7:31:37 PM	Cassian Andor	My Profile	Success	65.37.96.127	Saint Albans, West V...
9/26/2026, 7:31:23 PM	Cassian Andor	OfficeHome	Success	65.37.96.127	Saint Albans, West V..
9/26/2026, 7:28:43 PM	Cassian Andor	OfficeHome	Success	2600:3c02::2000:acff:f...	Atlanta, Georgia, US
9/26/2026, 7:28:39 PM	Cassian Andor	OfficeHome	Interrupted	2600:3c02::2000:acff:f...	Atlanta, Georgia, US
9/26/2026, 7:28:02 PM	Cassian Andor	OfficeHome	Interrupted	2600:3c02::2000:acff:f...	Atlanta, Georgia, US
9/26/2026, 7:09:20 PM	Cassian Andor	My Signins	Success	65.37.96.127	Saint Albans, West V..
9/26/2026, 7:09:17 PM	Cassian Andor	My Signins	Interrupted	65.37.96.127	Saint Albans, West V..
9/26/2026, 7:08:38 PM	Cassian Andor	Microsoft App Acces...	Success	65.37.96.127	Saint Albans, West V...

Hunting for AiTM Activity

IP address	Location	Conditional Ac...	Session ID
65.37.96.127	Saint Albans, West Virginia, US	Success	008d53ca-1606-ea13-ab16-a836bc1b43de
65.37.96.127	Saint Albans, West Virginia, US	Success	008d53ca-1606-ea13-ab16-a836bc1b43de
65.37.96.127	Saint Albans, West Virginia, US	Success	008d53ca-1606-ea13-ab16-a836bc1b43de
2600:3c02::2000:acff:...	Atlanta, Georgia, US	Success	008d53ca-1606-ea13-ab16-a836bc1b43de
2600:3c02::2000:acff:...	Atlanta, Georgia, US	Success	008d53ca-1606-ea13-ab16-a836bc1b43de
2600:3c02::2000:acff:...	Atlanta, Georgia, US	Success	008d53ca-1606-ea13-ab16-a836bc1b43de

DEFAULT LOG ANALYTICS

Setting Up Log Analytics

01 Workspace

One Log Analytics workspace. Destination table: resource-specific, so the table is SigninLogs.

02 Blade

Entra ID → Monitoring & health → Diagnostic settings → Add.

03 Categories

SigninLogs, NonInteractiveUserSignInLogs, ServicePrincipalSignInLogs, AuditLogs.

04 Destination

Send to Log Analytics. Name the setting entra-default-log-analytics.

KQL Query Example

Hunting for Device Code Logins

```
SigninLogs
| where TimeGenerated > ago(30d)
| where AuthenticationProtocol == "deviceCode"
| summarize SignIns = count(),
    Users = dcount(UserPrincipalName)
    by AppDisplayName
| top 15 by SignIns desc
```

KQL Query – Hunt for AiTM

```
//Session Token Theft - Same Session ID where IP and OS changed and (Browser or Device) changed.
SigninLogs
| where TimeGenerated > ago(7d)
| extend Browser = tostring(split(tostring(DeviceDetail.browser), " ")[0])
| extend OS = tostring(split(tostring(DeviceDetail.operatingSystem), "")[0])
| extend DeviceID = tostring(DeviceDetail.deviceId)
| where isnotempty(Browser) and isnotempty(OS)
| summarize IPs = make_set(IPAddress),
    Countries = make_set(tostring(LocationDetails.countryOrRegion)),
    Browsers = make_set(Browser),
    OSVersions = make_set(OS),
    DeviceIDs = make_set(DeviceID),
    FirstSeen = min(TimeGenerated),
    LastSeen = max(TimeGenerated),
    Count = count() by UserPrincipalName, SessionId
| extend MultiIP = array_length(IPs) > 1
| extend MultiBrowser = array_length(Browsers) > 1
| extend MultiOS = array_length (OSVersions) > 1
| extend MultiDevice = array_length(DeviceIDs) > 1
| where MultiIP and MultiOS and (MultiBrowser or MultiDevice)
| project UserPrincipalName, SessionId, MultiIP, MultiBrowser, Browsers,
    MultiOS, MultiDevice, IPs, Browsers, OSVersions, DeviceIDs, Countries, FirstSeen, LastSeen, Count
| sort by Count desc
```

Hardening 365 Against Identity-Driven Attacks

- We understand the attacks
- We know how to hunt for the attacks

…How do we defend against them?

ENTRA ID SECURITY DEFAULTS ≠ SECURE BY DEFAULT



Hardening 365 Against Identity-Driven Attacks

SECURITY DEFAULTS ≠ SECURE BY DEFAULT

INCLUDED IN DEFAULTS

Security Defaults

- ✓ **MFA registration**
  Every user must enroll an authenticator.
- ✓ **Admin MFA every sign-in**
  Privileged roles get challenged every time.
- ✓ **Legacy auth blocked**
  IMAP / POP / SMTP AUTH and old clients die.
- ✓ **Azure portal MFA**
  Resource Manager and admin portals require MFA.

REQUIRES CONDITIONAL ACCESS

Not Included in Defaults

- ✗ **Session & token control**
  No sign-in frequency or persistent-session policy.
- ✗ **Location, device, app**
  No named locations, compliant device, or app targeting.
- ✗ **Risk & exceptions**
  No ID Protection policies, guests, or break-glass paths.
- ✗ **Auth strength & guests**
  No phishing-resistant MFA requirement or guest rules.

As of today, security defaults and Conditional Access cannot run together. However, Microsoft is testing the the functionality to use individual security default settings alongside Conditional Access

WHAT IS CONDITIONAL ACCESS?



Microsoft Entra's policy engine for access decisions

Evaluates signals such as the user, application, device, location, and sign-in risk

Applies controls in real time: allow, block, or require additional authentication

Enables organizations to enforce consistent access rules across cloud resources

A FEW THINGS THAT CONDITIONAL ACCESS ALLOWS YOU TO DO

Require MFA for all users **AND** apply session lifetime policies

Require additional authentication if the sign-in is deemed risky

Block all sign-ins from accounts with an active risk detections

Block legacy authentication methods

Require Phishing-Resistant Authentication

Block device code flow authentication entirely

WHAT IS RISK-BASED CONDITIONAL ACCESS?

Evaluates sign-in risk signals and applies controls when risk has been detected on an account

Anonymous IP address

Anomalous Token

Atypical travel

Impossible travel

Malicious IP address

Unfamiliar sign-in properties

These detections are great for raising flags on AiTM and Device Code Phishing Attacks

RISK-BASED CONDITIONAL ACCESS LIMITATIONS

Risk-based Conditional Access requires **Entra ID P2 licenses**

Conditional access is like checking a user’s badge at the front door. It doesn’t check to see if the people already inside are swapping badges

MAKE SURE YOU HAVE BREAK GLASS ACCOUNTS

RISK-BASED CONDITIONAL ACCESS - TECHNICAL LIMITATIONS

IPv6 - Obfuscated Location and Device Properties

Signal and indicator reliability (IP Geolocation)

Timing

FIDO2 / PASSKEYS

Conditional Access Policies can be used to enforce phishing-resistant authentication methods such as passkeys

Passkeys require physical proximity, which breaks AiTM attacks.



Hardening 365 Against Identity-Driven Attacks

Moving Vandalia Health to Passkeys

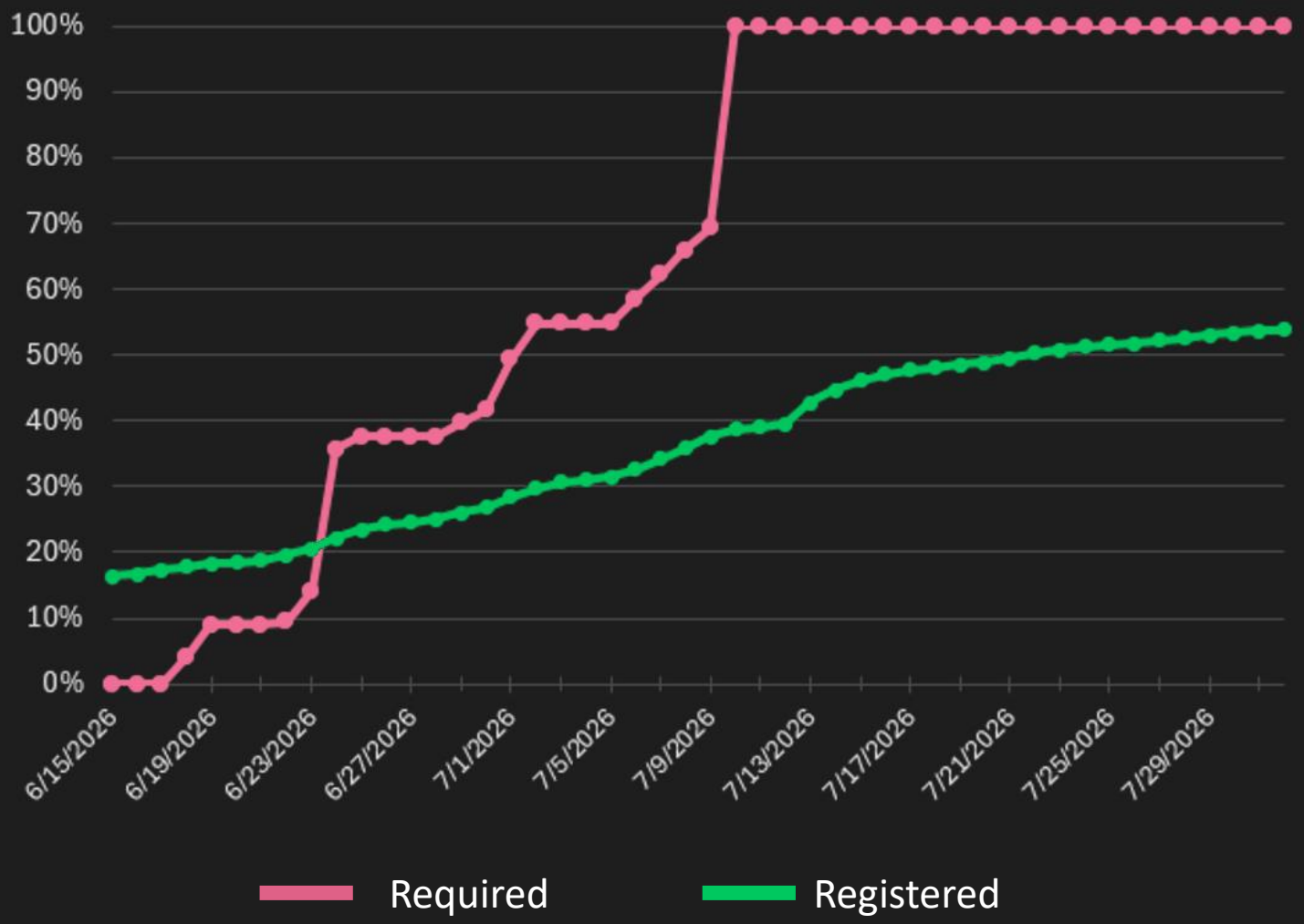
18k **User Accounts in Entra**
(non-guest users or service accounts)

30k Successful Interactive Sign-ins / week

iOS **6,490**

1,532

11k Users Registered with Passkey



FIDO2 / PASSKEYS

Always require an additional authentication method (MFA, TAP, location, domain joined device) for self service portals such as Microsoft's Security Info page.



THE GOOD NEWS

Microsoft built a policy to block device code flow sign-ins
All you have to do is enable it!

In September, Microsoft moved towards making Passkeys the default sign-in method for all Entra tenants

---

By February 1st, SMS and Voice methods for MFA will be minimally supported in Entra. Work towards moving these users to a more secure authentication method.

“FREE” CONTROLS

- Updated Security Defaults
  - If your tenant was set up after July of 2026, device code flow is blocked
  - Passkeys are becoming the preferred authentication method

- Authentication Methods Policies
  - Allows you to enable or disable specific authentication methods
  - This could allow you to enforce passkeys for all users without needing conditional access policies

Method	Target	Enabled
Built-In		
Passkey (FIDO2)	2 groups	Yes
Microsoft Authenticator	1 group	Yes

[PASS]KEY TAKEAWAYS

Identity-driven attacks like AiTM and Device Code Flow phishing are rising year after year

Conditional Access can help **detect** and respond to risky sign-ins (with limitations)

Passkeys can help prevent these attacks


Q&A